

PHANTOM ACCESS

Cloud Identity Attack & Zero Trust Defense Lab

A detailed Kali Linux VM installation, investigation, containment, and after-action guide

CASE FILE

PA-042 / NORTHSTAR FINANCIAL

Prepared by Andrew W.

ENVIRONMENT	LAB TYPE	VERSION
Kali Linux VM	Safe browser simulation	1.0 / 08 Aug 2026

EDUCATIONAL / PORTFOLIO USE

No live tenant, real credential, exploit, or external identity provider is used.

SECTION 00

Document control and safe-use statement

The lab is intentionally realistic in presentation while remaining fully fictional and non-operational.

Purpose

This guide documents how to install and run Phantom Access inside a Kali Linux virtual machine, then complete the simulated cloud-identity incident from initial alert through evidence review and after-action reporting. It is written so a learner can reproduce the lab, explain what each screen represents, and defend the technical choices in a portfolio review or interview.

Scope and boundaries

- In scope: local extraction, npm dependency installation, Vite development hosting, identity telemetry interpretation, simulated terminal investigation, defense selection, evidence correlation, and final reporting.
- Out of scope: credential collection, tenant access, exploitation, real token acquisition, live cloud changes, phishing, malware, persistence, or unauthorized testing.
- All names, organizations, public IP addresses, device identifiers, cloud resources, commands, events, and results shown in the case are fictional lab data.

SAFETY RULE Run the project only in an environment you own or are authorized to administer. Do not expose the Vite development server directly to the public internet. The simulated phantom commands are visual content in the web application; they do not execute against Kali or any cloud tenant.

Document record

Field	Value
Title	Phantom Access: Cloud Identity Attack & Zero Trust Defense Lab Guide
Case	PA-042 - Northstar Financial
Case identity	Maya Chen - Finance Administrator
Environment	Kali Linux virtual machine; Node.js 22.13.0 or newer; npm
Application	Phantom Access 0.1.0; local browser-based educational simulation
Evidence set	15 screenshots captured 07 Aug 2026
Revision	Version 1.0 - 08 Aug 2026

How to use this guide

Read Sections 1-3 before launching the lab. During execution, record observations at each checkpoint rather than clicking directly to the end. The later analysis sections explain why some apparently helpful actions, especially a password-only reset or source-IP block, are insufficient once a valid cloud session has been replayed.

SECTION 01

Guide map and learning outcomes

The exercise combines environment setup, attack reconstruction, response engineering, and evidence-based communication.

Guide map

Section	What you will do	Primary evidence
1. Prepare	Create or confirm the Kali VM, network mode, and Node/npm prerequisites.	System checks
2. Install and host	Extract the archive, identify the project root, install dependencies, and start Vite.	Figures 1-3
3. Orient	Read the mission brief and establish the identity, organization, and investigation objectives.	Figure 4
4. Reconstruct	Replay seven attack events from valid-account use to sensitive-data access.	Figures 5-6
5. Investigate	Interpret six simulated commands covering identity, MFA, sessions, audit, Zero Trust, and response.	Figures 7-8
6. Defend	Compare prevention, containment, and limited controls using the weighted scoring model.	Figures 9-12
7. Preserve	Correlate evidence, maintain chain of custody, and validate the final report.	Figures 13-15
8. Explain	Map observations to ATT&CK, Zero Trust principles, incident-response phases, and portfolio outcomes.	Analysis tables

Learning outcomes

- Distinguish successful authentication from trustworthy access by combining identity, device, location, session, and resource context.
- Explain how MFA request generation can convert a stolen password into an authenticated session when the user approves an unexpected prompt.
- Recognize why password reset alone does not necessarily invalidate an already issued browser session or refresh token.
- Prioritize controls that prevent session issuance, revoke active access, remove persistence, and reduce future exposure.
- Relate the scenario to MITRE ATT&CK techniques T1078, T1621, T1539, T1098.005, and T1213 without treating ATT&CK as a risk score.
- Document evidence and response decisions in a form that another analyst can review and reproduce.

Completion standard

A complete run reaches a 100/100 defense score, reviews all seven evidence events, records the six Case Console findings, and downloads the after-action text report. A strong learner submission also explains the control-ordering logic and identifies the legacy conditional-access decision as the central policy gap.

SECTION 02

Lab architecture and prerequisites

Phantom Access is served by a local Vite process inside Kali and viewed through a browser; no live identity system sits behind it.

Logical architecture

Host or Kali browser	HTTP	Kali Linux VM	5173	Vite + Phantom Access UI
----------------------	------	---------------	------	--------------------------

The browser requests the application from the Vite development server. The interface loads a fixed fictional case and uses local state to track the attack step, executed console simulations, selected controls, evidence filters, and report output. Nothing in the scenario requires a cloud tenant, identity-provider credential, database, or command-and-control channel.

Recommended virtual machine profile

Resource	Recommended	Why it matters
CPU	2 virtual CPUs	Sufficient for development build and browser rendering.
Memory	4 GB minimum; 8 GB comfortable	Kali desktop, browser, and Node package tooling run together.
Disk	25 GB free	Allows the OS, npm cache, dependencies, project, and screenshots.
Network	NAT for setup; bridged/host-only only when needed	npm install requires outbound package access; host-to-guest browsing requires a reachable interface.
Snapshot	Before installing dependencies	Provides an easy rollback point without deleting evidence or unrelated work.

Software prerequisites

- Kali Linux 64-bit with a graphical browser and terminal.
- Node.js 22.13.0 or newer, as required by the project package manifest.
- npm, unzip, and network access to the npm registry during dependency installation.
- The Phantom Access ZIP archive copied into the Kali user Downloads directory.

NETWORK POSTURE For the safest demonstration, browse to localhost from inside Kali. If the host computer must open the VM address, allow only the required local path and do not create public router port forwarding.

SECTION 03

Prepare the Kali Linux VM

Confirm the environment before extracting the project so failures are easy to isolate.

Phase A - confirm the VM

1. Start the Kali virtual machine and sign in with the normal, non-root lab account.
2. Open a terminal and confirm the working directory and available disk space.

```
pwd
df -h .
ip addr show
```

3. Confirm that the archive is present. The examples in this guide use the Downloads directory.

```
cd ~/Downloads
ls -lh phantom-access.zip
```

Phase B - verify required tools

```
unzip -v | head
node --version
npm --version
```

The Node version must be at least 22.13.0. If the command is missing or reports an older version, install a supported Node.js release through a trusted package source, then reopen the terminal and verify again. Do not continue based only on a successful npm version check; npm can be present while Node is below the project requirement.

Phase C - choose the access path

Goal	Recommended URL	Networking note
Browse inside Kali	http://localhost:5173/	Works with NAT and does not require host-to-guest routing.
Browse from the host	http://<KALI-VM-IP>:5173/	The VM address must be reachable; bridged, host-only, or an explicit NAT mapping may be required.
Share publicly	Not recommended	Vite dev mode is not a production perimeter service. Build and deploy through an approved platform instead.
CHECKPOINT Record the Node version, npm version, Kali VM address, archive size, and chosen browsing path in your lab notes. These values make later troubleshooting reproducible.		

Expected result

The VM has enough disk space, the ZIP appears in Downloads, Node and npm return valid versions, and you know whether the browser will run inside Kali or connect from the host system.

SECTION 04

Extract the Phantom Access archive

Create a clean project directory, inspect the archive layout, and avoid overwriting a previous extraction by accident.

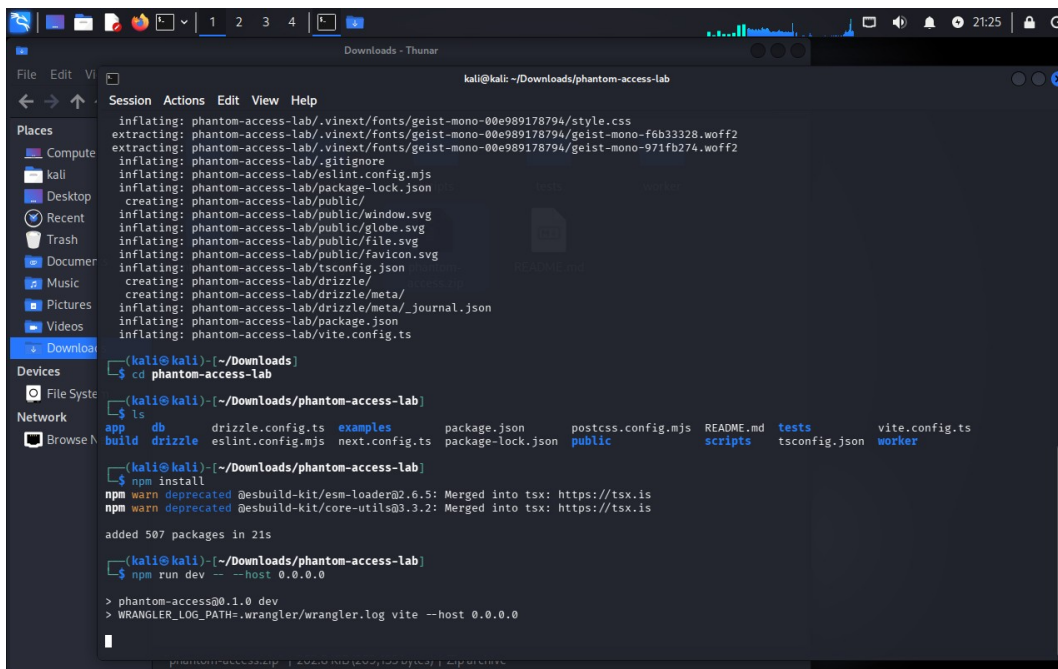


Figure 1. Kali terminal showing archive extraction, project discovery, npm installation, and the initial launch command.

Recommended extraction sequence

```
cd ~/Downloads
unzip phantom-access.zip
ls
cd phantom-access
ls
```

The current archive is packaged with a top-level phantom-access directory. After changing into it, the directory listing should include package.json, package-lock.json, app, public, scripts, and README.md. Treat the presence of package.json as the definitive indicator that you are at the project root.

IF UNZIP ASKS TO REPLACE .NPMRC That prompt means a file with the same name already exists in the extraction target, usually because the archive was unpacked there before. Press N or Ctrl+C when you want to preserve the existing copy, then extract into a new clean directory. Choose A only when you intentionally want every matching project file replaced and you have preserved any local changes.

SECTION 05

Locate the project root and install dependencies

Mixed screenshots may show an older outer folder, but npm must always run where package.json is located.

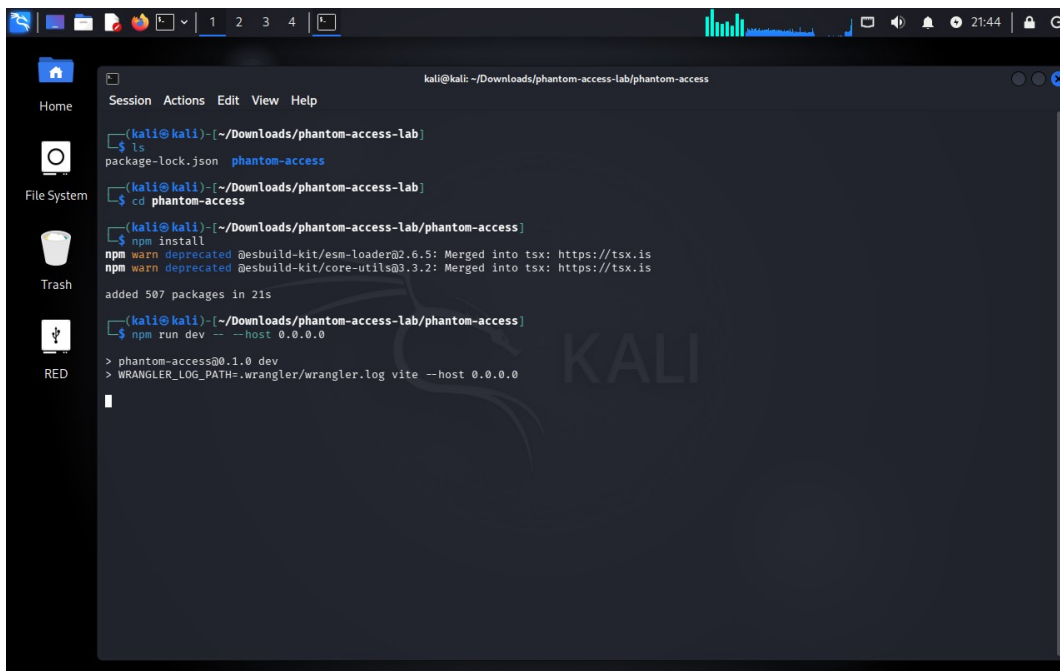


Figure 2. Dependency installation and Vite launch from the nested Phantom Access project directory.

Resolve the folder layout

A previous extraction shown in Figure 2 used an outer phantom-access-lab folder containing an inner phantom-access project. The current package normally extracts directly to phantom-access. Do not copy the screenshot path blindly: use ls and test for package.json.

```
pwd
ls
test -f package.json && echo 'project root found' || echo 'not at project root'
```

Install from the root

```
npm install
```

npm reads package.json and package-lock.json, resolves the pinned dependency graph, and creates node_modules. A successful installation returns to the prompt without a fatal npm ERR! message. Warnings should be reviewed, but warnings and errors are not equivalent. Preserve the terminal output or capture a screenshot if this is part of a graded lab.

DO NOT USE SUDO NPM INSTALL Installing project dependencies as root can create ownership problems in the project and npm cache. Use the normal Kali account unless a documented package-management step specifically requires elevation.

Installation checkpoint

- package.json is in the current directory.
- npm install completes without a fatal error.
- The node_modules directory now exists.

SECTION 06

Start the local server and open the lab

The `--host` argument exposes Vite on the VM interfaces while the application remains a local development service.

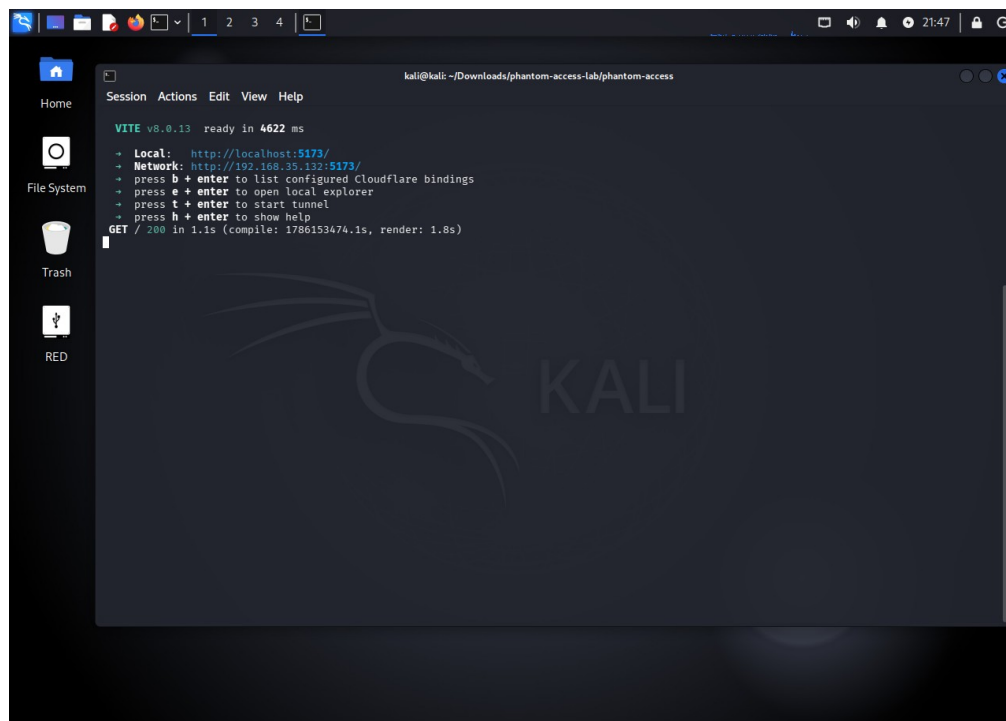


Figure 3. Vite ready state with local and VM-network URLs and a successful HTTP 200 response.

```
npm run dev -- --host 0.0.0.0
```

The project script starts Vite. The extra double dash forwards the remaining argument to Vite, and 0.0.0.0 tells it to listen on all VM interfaces. Figure 3 shows two valid addresses: `http://localhost:5173/` for a browser inside Kali and `http://192.168.35.132:5173/` for a device that can route to that VM address. Your address will probably differ.

Validate the service

1. Leave the Vite terminal running; opening a new terminal is safer than stopping the process to issue checks.
2. Open the appropriate URL and wait for the Mission Brief page.
3. Return to the Vite terminal and confirm a GET / request with status 200.
4. Stop the server only when finished by returning to its terminal and pressing Ctrl+C.

HOSTING MEANING This procedure hosts a development instance inside the Kali VM. It is appropriate for an isolated demonstration or local portfolio recording. It is not a permanent production deployment and should not be exposed directly to the internet.

SECTION 07

Read the mission brief

Establish the identity, business context, and objectives before examining technical telemetry.

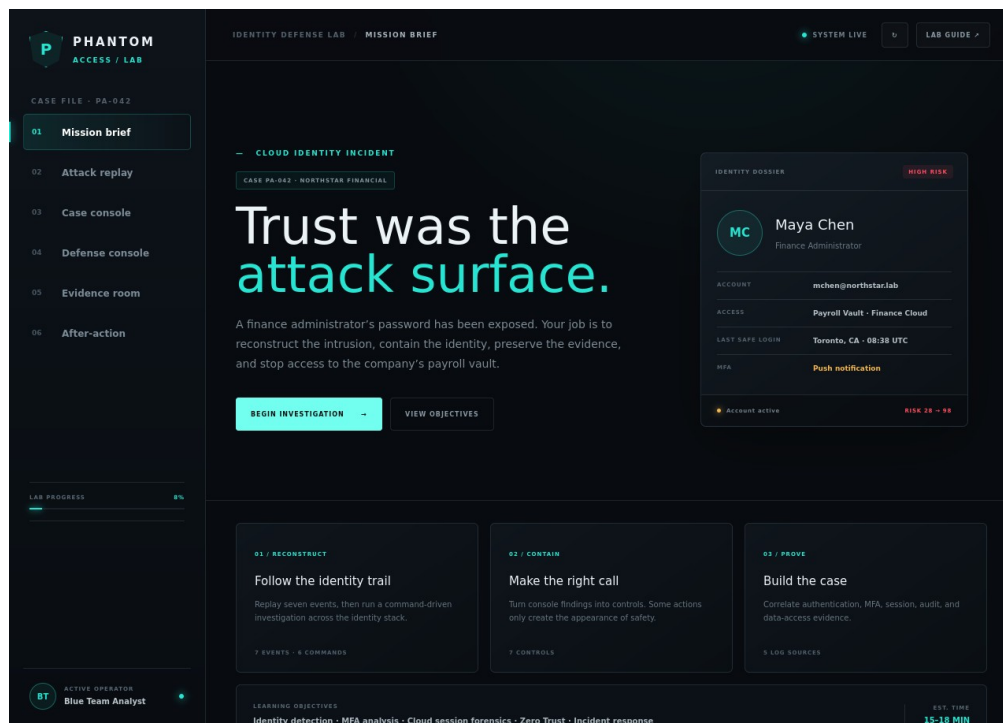


Figure 4. Mission Brief for Case PA-042 with the identity dossier and five learning objectives.

Case facts

Field	Observed value	Analyst significance
Organization	Northstar Financial	Fictional financial context makes payroll data a high-sensitivity resource.
Identity	Maya Chen	Single principal ties authentication, MFA, session, audit, and data events together.
Role	Finance Administrator	Privileged access increases business impact and containment urgency.
Principal	mchen@northstar.lab	Fictional lab domain prevents accidental connection to a real tenant.
Case	PA-042	Stable identifier for evidence, command, and report correlation.

Analyst orientation

Do not begin with the assumption that the password itself explains the full incident. The mission is to reconstruct an identity attack chain: valid credentials open the door; contextual signals show the access is abnormal; repeated MFA requests cause an approval; a cloud session is

replayed; a new authentication method creates persistence; and a sensitive repository is accessed.

RECORD BEFORE PROCEEDING Write a one-sentence initial hypothesis and identify the three telemetry sources you expect to be most important. Revisit the hypothesis after the Evidence Room to show how evidence changed or confirmed your assessment.

SECTION 08

Attack Replay: detect the early identity signals

The first events show why a technically valid sign-in can still be high risk.

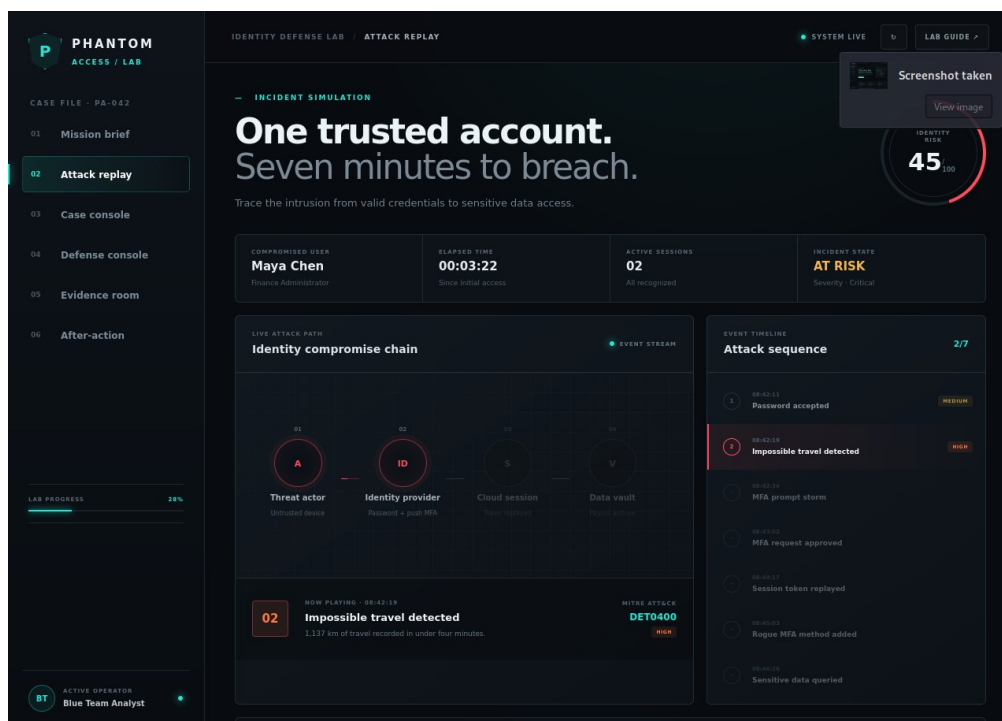


Figure 5. Early Attack Replay state highlighting impossible travel and a rising risk score.

What to observe

- 08:42:11 - Password accepted. The credential validation succeeds from an unrecognized browser. This aligns with the lab's use of Valid Accounts (T1078).
- 08:42:19 - Impossible travel. The user context shifts from Toronto to Ashburn in four minutes. The application labels the detection DET0400; this is a detection identifier in the scenario, not an ATT&CK technique.
- The risk score reaches 45 by step two. The score is a lab visualization of accumulating severity, not a standardized industry probability.

Interpretation

Password acceptance proves only that the supplied secret matched. Trust should also consider source, device posture, location, behavior, session history, and the sensitivity of the requested resource. The impossible-travel signal is especially important because it arrives before the later persistence and data-access events. An identity platform that evaluates risk at sign-in could interrupt the chain before an MFA-approved cloud session is issued.

ANALYST QUESTION Which response would you take at this point if you had only the first two events: block, challenge, monitor, or contain? State what additional evidence you would need before disabling the identity.

SECTION 09

Attack Replay: reconstruct the full compromise

Advance through all seven events and explain how each event changes the adversary's access or persistence.

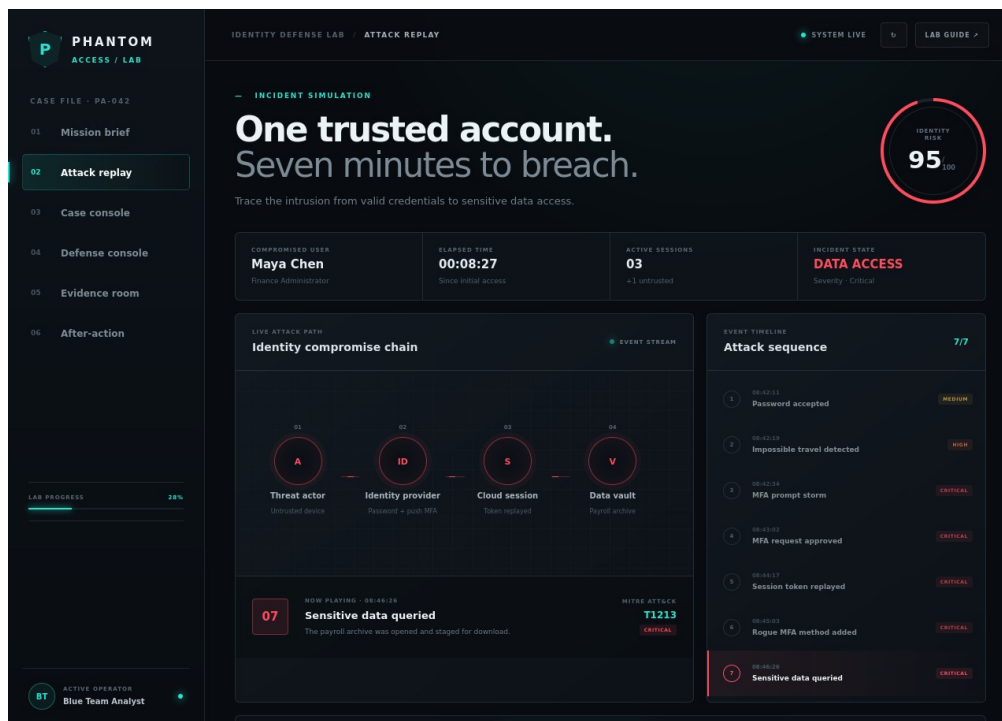


Figure 6. Completed seven-event attack replay with risk 95 and sensitive data staged.

The critical transitions

1. Credential to challenge: the stolen or abused valid password initiates access but does not yet explain the MFA success.
2. Challenge to approval: seven pushes in 41 seconds create pressure; the seventh request is approved from Maya's registered phone.
3. Approval to portable access: a valid web session appears on an unmanaged Linux device, indicating the authenticated session is no longer bound to the expected context.
4. Access to persistence: a rogue authenticator is registered, giving the intruder another future authentication path.
5. Persistence to impact: the payroll archive is opened and 4.8 GB is staged for download.

Why the sequence matters

Each control opportunity is time-sensitive. Phishing-resistant MFA or risk-based access can prevent the session from being issued. Session revocation can contain an issued token. Removing the rogue factor closes persistence. Evidence preservation and repository review

determine impact. A password change acts on only one part of the chain and therefore receives limited credit in the lab.

SECTION 10

Attack-chain analysis worksheet

Use the event sequence as a defensible timeline, not merely a set of red alerts.

Time	Event	ID	Security meaning	Best immediate question
08:42:11	Password accepted	T1078	Valid credentials establish initial authenticated context.	Was this device, source, and location expected?
08:42:19	Impossible travel	DET0400	Behavior conflicts with the user's recent location.	Did the policy enforce the risk signal?
08:42:34	MFA prompt storm	T1621	Seven prompts create approval pressure.	Which request was approved and from which session?
08:43:02	MFA approved	T1621	Challenge seven converts the attempt into a valid cloud session.	Was the approval expected by the user?
08:44:17	Session replayed	T1539	The same session context appears on another unmanaged device.	Which token fingerprint and devices correlate?
08:45:03	Rogue MFA added	T1098.005	A new authenticator creates persistence.	Who owns RAVEN-31 and was change approval present?
08:46:26	Sensitive data queried	T1213	Payroll data is opened and staged, producing impact.	What records were accessed or exported?

Minimum evidence to preserve

- Authentication and risk events with timestamps, principal, source, device, browser, result, and policy decision.
- MFA transaction sequence, challenge numbers, delivery method, user/device response, and linked session identifier.
- Session issuance, token or fingerprint correlation, refresh activity, device trust, and revocation result.
- Authentication-method audit record, target principal, actor, device, method type, and change result.
- Payroll-vault access logs, queries, objects, staging volume, downloads, and downstream destinations.

DO NOT OVERCLAIM The interface states that 4.8 GB was staged for download. Staging is evidence of preparation and exposure, but it is not automatically proof that all 4.8 GB left the environment. The final report should distinguish observed access, staging, and confirmed exfiltration.

Suggested analyst narrative

At 08:42:11, an unrecognized browser successfully authenticated as Maya Chen. Eight seconds later, impossible travel indicated a location conflict. Repeated MFA requests culminated in an approved seventh push. The resulting session was observed on an unmanaged Linux device, followed by registration of an unknown authenticator and access to the payroll archive. The correlated sequence supports a high-confidence identity compromise with persistence and sensitive-data exposure.

SECTION 11

Case Console: begin the simulated investigation

The new case-file terminal turns the evidence into a command-driven show without running live security commands.

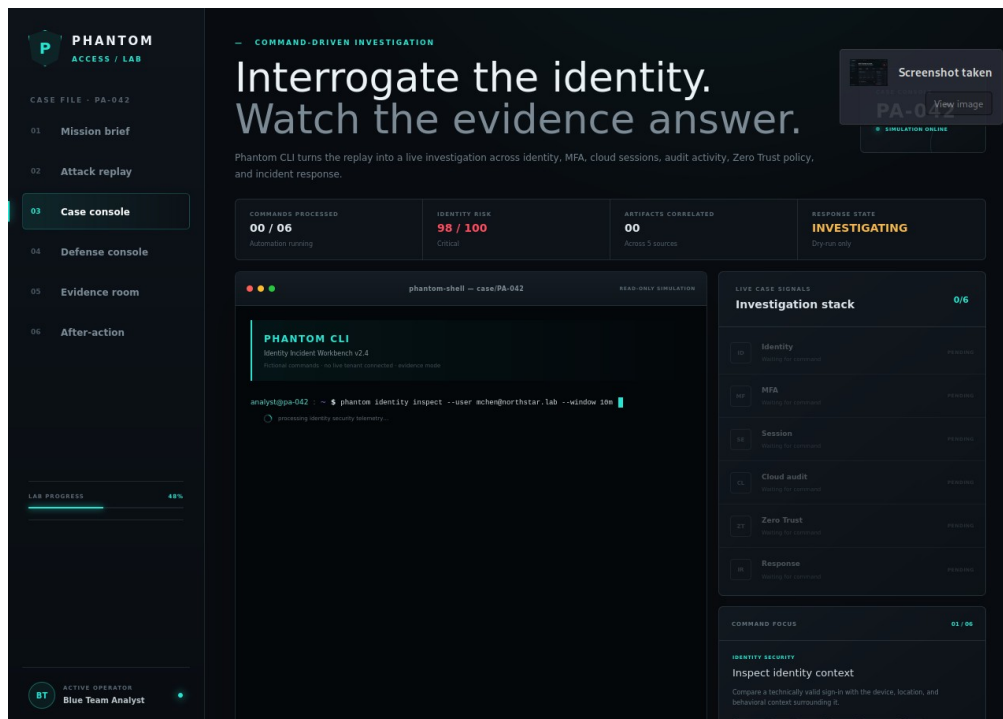


Figure 7. Case Console beginning the first of six simulated investigations.

Operating model

Select Run next command to process one scripted investigation at a time. The terminal animation is designed to communicate analyst reasoning: each command names the subject, time window, data domain, and analytic intent; the output then exposes a decisive signal. No binary named phantom is installed in Kali, and copying the commands into the real terminal is neither required nor useful.

First command

```
phantom identity inspect --user mchen@northstar.lab --window 10m
```

- credential_validation=SUCCESS confirms the password step.
- impossible_travel=TRUE links Toronto and Ashburn within four minutes.
- device_trust=UNMANAGED and sign_in_risk=HIGH add context that the raw success result lacks.

PRESENTATION TIP For a portfolio demo, pause after each command and explain the decision it enables. The value of the console is not the animation alone; it is the visible relationship between telemetry, hypothesis, and next action.

SECTION 12

Case Console: complete all six investigations

The completed console correlates identity, MFA, session, audit, policy, and response evidence into one case.

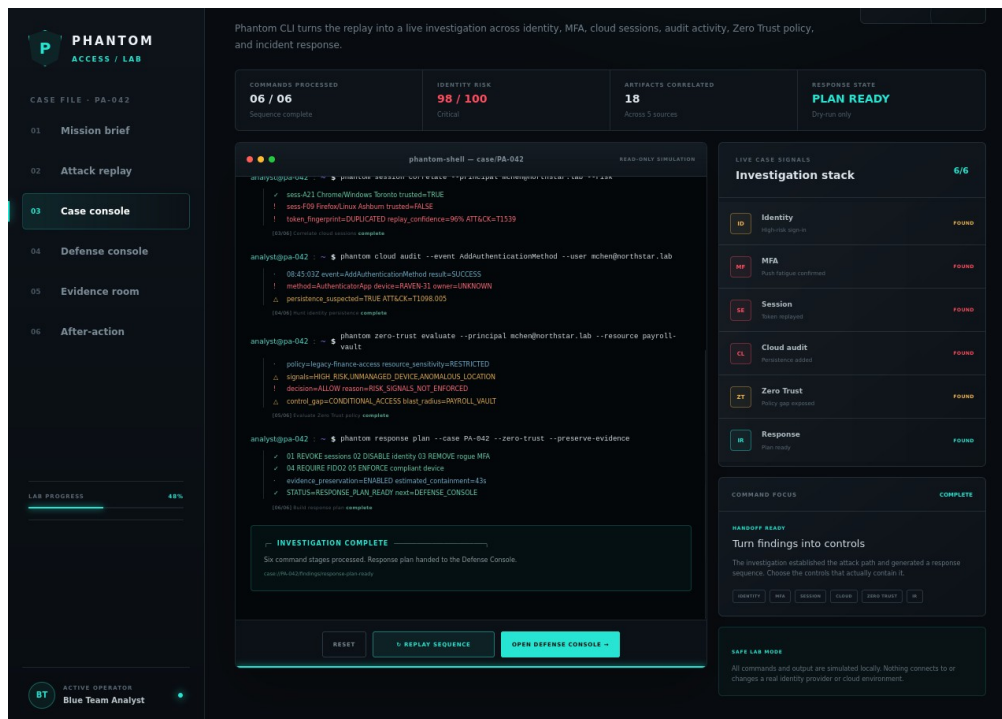


Figure 8. Completed Case Console with six signals found and the response plan ready.

Completion signals

Domain	Decisive result	Why it changes the case
Identity security	High-risk unmanaged sign-in; impossible travel	Successful password validation is no longer treated as sufficient trust.
MFA attack	7 prompts / 41 seconds; challenge 07 approved	Links user approval to the attacker-associated session.
Cloud access	Duplicated token fingerprint; 96% replay confidence	Explains access from the unmanaged Linux device.
Cloud audit	Unknown device RAVEN-31 added authenticator	Shows post-compromise persistence.
Zero Trust	ALLOW despite high risk, unmanaged device, anomalous location	Identifies the policy enforcement gap.
Incident response	Revoke, disable, remove factor, require FIDO2, enforce device	Creates a sequenced containment and recovery plan.

The response plan reports an estimated containment time of 43 seconds in the simulation. Treat this as a scenario metric, not a guarantee for a real tenant. Production containment time depends on platform propagation, token lifetimes, automation, approval paths, evidence requirements, and the analyst's permissions.

CHECKPOINT Do not proceed until the Case Console reads 6 / 6 and STATUS=RESPONSE_PLAN_READY. Capture the screen and record the control gap: risk signals existed, but the legacy finance policy did not enforce them.

SECTION 13

Case Console command reference

Read each fictional command as an analytic question and each output as a claim that must be supported by evidence.

#	Command family	Analytic question	Key output
1	identity inspect	Was the successful sign-in trustworthy?	Credential success; impossible travel; unmanaged device; risk 67.
2	mfa analyze	Did repeated pushes produce an approval?	7 prompts in 41s; challenge 07 approved; T1621.
3	session correlate	Was an authenticated session reused elsewhere?	Trusted sess-A21 vs untrusted sess-F09; duplicate fingerprint; 96%.
4	cloud audit	Was an authentication method added for persistence?	AddAuthenticationMethod success; RAVEN-31 unknown; T1098.005.
5	zero-trust evaluate	Should payroll-vault access have been allowed?	High risk + unmanaged + anomalous; decision ALLOW; policy gap.
6	response plan	What safe containment sequence follows?	Revoke, disable, remove rogue MFA, require FIDO2, enforce compliant device.

Full command set

```
phantom identity inspect --user mchen@northstar.lab --window 10m
phantom mfa analyze --user mchen@northstar.lab --correlate
phantom session correlate --principal mchen@northstar.lab --risk
phantom cloud audit --event AddAuthenticationMethod --user mchen@northstar.lab
phantom zero-trust evaluate --principal mchen@northstar.lab --resource payroll-vault
phantom response plan --case PA-042 --zero-trust --preserve-evidence
```

Response-plan ordering

1. Preserve volatile identifiers and timestamps before destructive or state-changing actions where operationally feasible.
2. Revoke sessions to invalidate the replayed access path.
3. Temporarily disable the compromised identity to prevent fresh authentication during triage.
4. Remove the rogue authentication method and review all factor registrations.
5. Reset the credential and require phishing-resistant MFA for recovery.
6. Enforce compliant-device and sign-in-risk policy before returning the account to service.

SIMULATION BOUNDARY These commands are intentionally fictional. In a real incident, responders would use their organization's approved identity, SIEM, cloud, and case-management tools under documented authorization and change control.

SECTION 14

Defense Console method and scoring

The scoring model rewards controls that interrupt the active attack path and reduce the chance of recurrence.

Control weights

Control	Role	Points	Rationale
Require phishing-resistant MFA	Prevent	+25	A device-bound FIDO2 method stops the push-fatigue path before session issuance.
Enforce risk-based access	Prevent	+20	High-risk sign-ins from unmanaged devices and anomalous locations are denied or strongly challenged.
Revoke active sessions	Contain	+20	Invalidates active browser and refresh-token access, including the replayed session.
Temporarily disable account	Contain	+15	Blocks new authentication while the identity is investigated and recovered.
Remove rogue MFA method	Contain	+15	Closes the persistence mechanism registered after compromise.
Reset password only	Limited	+4	Changes the secret but may leave an existing session valid.
Block observed source IP	Limited	+3	Can reduce immediate traffic but is easy to route around and does not revoke tokens.

Outcome thresholds

Score	State	Meaning
0-44	Exposed	The breach remains active or the selected actions fail to address the primary access path.
45-74	Partial	Access may be disrupted, but prevention, persistence removal, or recovery is incomplete.
75-100	Contained	The selected control set contains the incident and meaningfully improves future resistance.

How to test

1. Observe the zero-control baseline and record the active breach state.
2. Select one or more controls and watch both the score and attack-chain markers change.
3. Compare a limited-action set with a containment set; state which attacker capability remains.
4. Select all seven controls to reach the documented 100/100 completion state.

INTERPRET SCORES CAREFULLY The numbers are a teaching model for this fixed scenario. They are not control effectiveness percentages, a real risk calculation, or evidence that a single product guarantees prevention.

SECTION 15

Defense Console baseline: breach active

Start from zero to understand what the environment looks like before a responder acts.

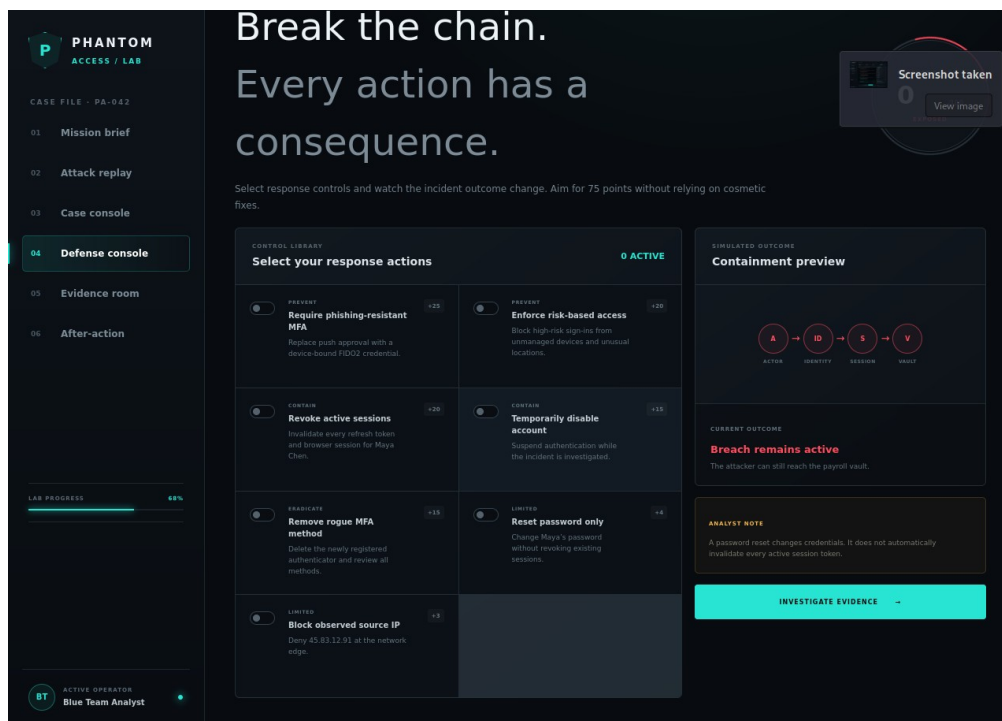


Figure 9. Defense Console baseline with score 0 and the breach still active.

Baseline interpretation

At 0/100, every attacker capability remains available: the high-risk sign-in was allowed, an MFA approval produced a session, that session was replayed, a new authentication method was added, and payroll data was queried. The purpose of this baseline is to make later score changes explainable. It also prevents the final screenshot from hiding the fact that different controls act at different phases.

Questions to answer

- Which event could have been prevented before a session existed?
- Which control is necessary after a session has already been replayed?
- Which control removes persistence but does not necessarily terminate the current session?
- Which evidence must be collected before returning the user to service?

EXPECTED OBSERVATION The attack-chain status should remain active and the score should be 0 before you begin control testing. If controls are already selected, clear them so the baseline is preserved.

SECTION 16

Defense Console experiment: score 43, still exposed

A mix of useful and limited actions can remain below the containment threshold when session control is missing.

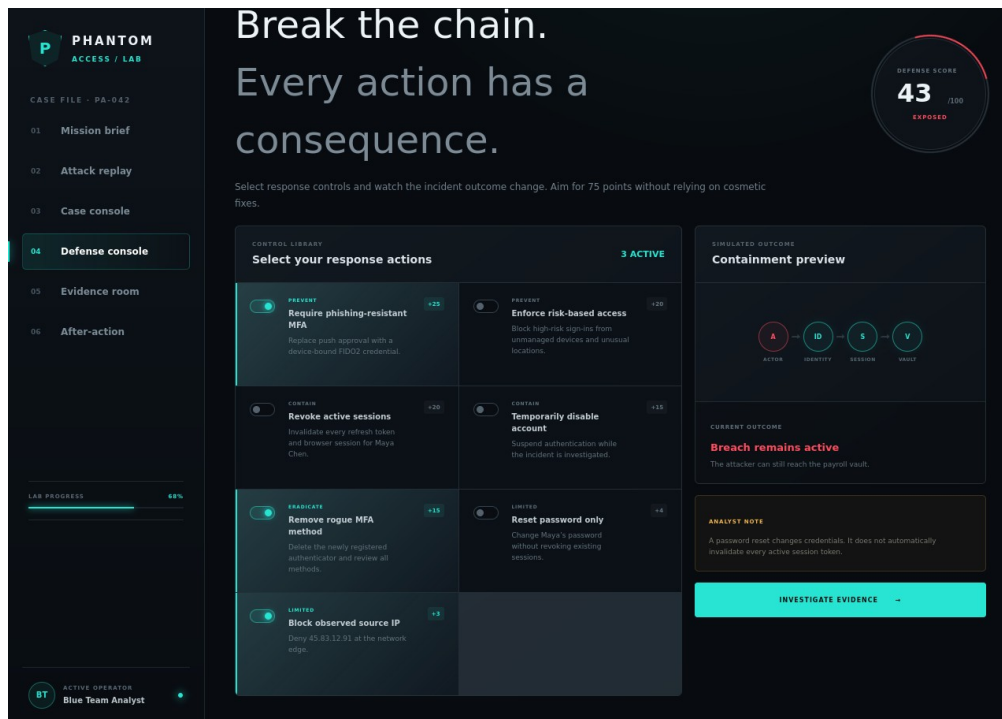


Figure 10. Defense score 43 with FIDO2, rogue-factor removal, and IP blocking selected.

Why 43 is not enough

The selected set earns 25 points for phishing-resistant MFA, 15 for removing the rogue method, and 3 for blocking the observed source IP. These actions strengthen future authentication and remove persistence, but the existing replayed session has not been revoked. The attacker may retain access until the token expires or another control terminates it. The lab therefore keeps the case in the exposed state.

Control lesson

- Future-proofing is not the same as immediate containment.
- Removing a rogue factor closes a persistence path but does not automatically invalidate every session.
- IP blocking addresses a source observation, not the identity or token itself; a new source can bypass it.

ANALYST DECISION Add the control that directly invalidates active browser and refresh-token access. Predict the new score and explain why the attacker experience changes even before preventive policy is fully improved.

SECTION 17

Defense Console experiment: score 54, access disrupted

Containment actions can interrupt the incident even when long-term prevention is incomplete.

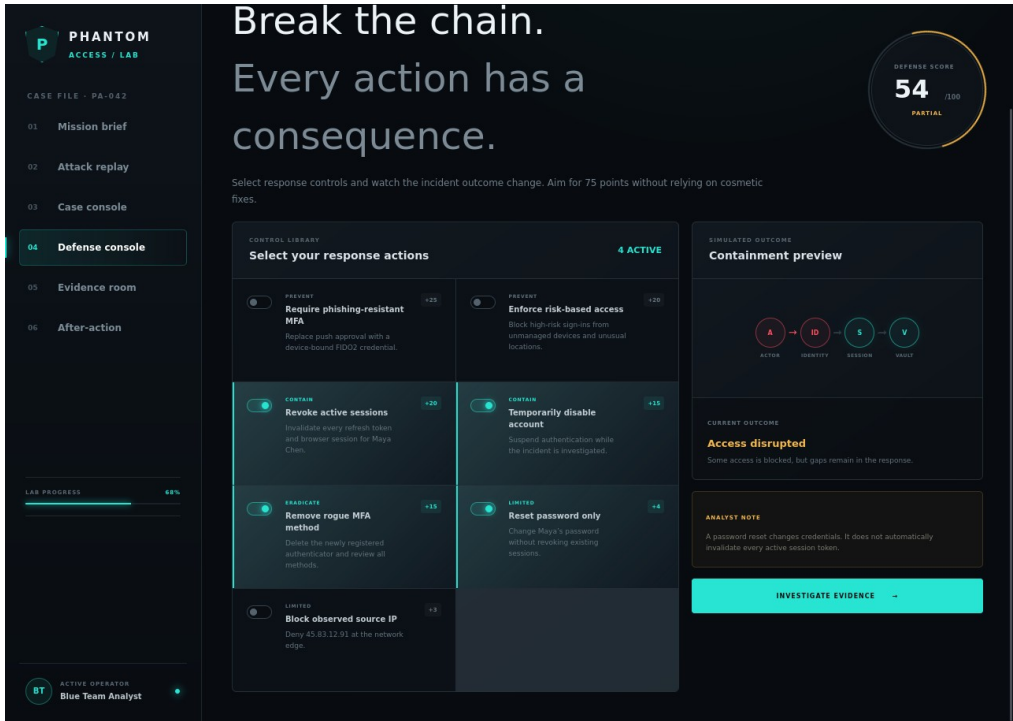


Figure 11. Defense score 54 with session revocation, account disablement, rogue-factor removal, and password reset.

Why the state is partial

This selection directly disrupts access: session revocation targets the stolen token, temporary disablement blocks fresh authentication, rogue-factor removal closes persistence, and password reset replaces the known secret. The total is 54. The immediate incident is better controlled than in the 43-point experiment, yet the environment has not implemented phishing-resistant MFA or enforced risky-sign-in and compliant-device conditions. The account could return to a similar exposure after recovery.

Response versus hardening

Immediate response	Long-term hardening
Revoke sessions; disable identity; remove unauthorized factors; preserve and review evidence.	Require FIDO2; enforce risk and device posture; review legacy policy exceptions; monitor new factor registrations.
KEY DISTINCTION Containment limits current attacker access. Eradication removes persistence and compromised artifacts. Recovery restores the identity safely. Hardening changes the control environment so the same sequence is less likely to succeed again.	

SECTION 18

Defense Console completion: score 100, incident contained

Activate the complete control set and verify both the final score and the attack-chain state.

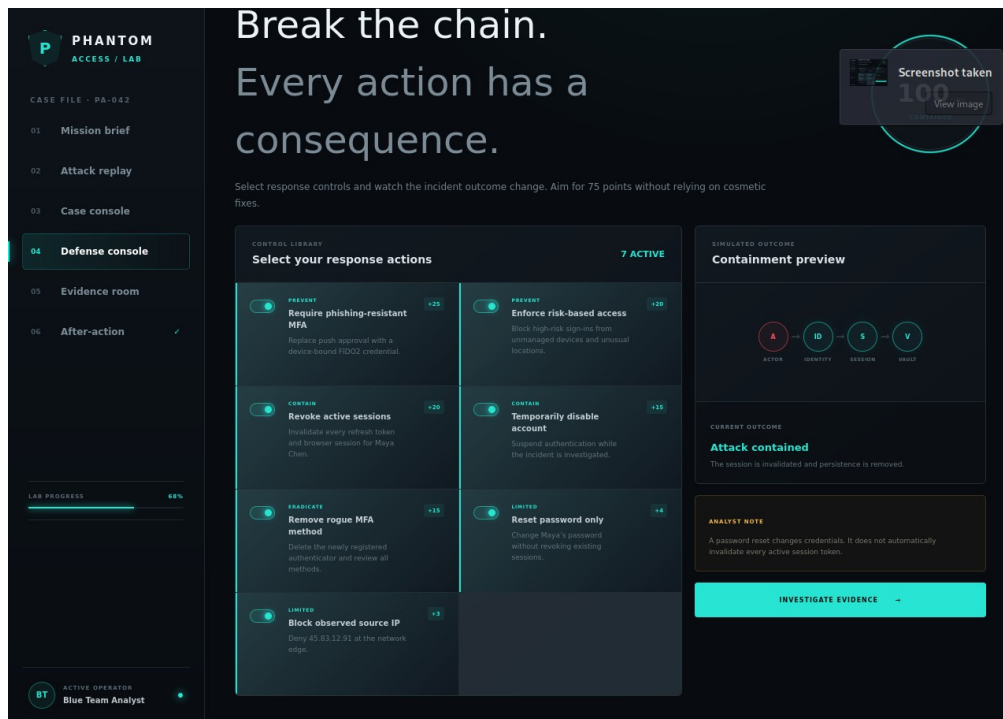


Figure 12. Defense score 100 with all seven controls active and the incident contained.

What the full set accomplishes

- Prevention: phishing-resistant MFA and risk-based access reduce the probability that stolen credentials and a hostile device produce a trusted session.
- Containment: session revocation and temporary disablement interrupt active and new access.
- Eradication: removing the rogue MFA method closes the persistence path.
- Credential recovery: password reset replaces the compromised secret but is deliberately not treated as sufficient on its own.
- Tactical restriction: source-IP blocking adds short-lived friction while identity-centered controls take effect.

Completion evidence

Capture the 100/100 screen, note every active control, and record the final incident state as contained. In a real incident, this score would not close the case by itself: the responder would still validate token revocation, inspect data access, notify stakeholders, restore the account under stronger policy, and continue monitoring.

DO NOT SKIP EVIDENCE REVIEW Containment protects the environment; it does not explain the scope of exposure. Continue to the Evidence Room even after the interface reaches 100.

SECTION 19

Control-selection analysis

Match each control to the capability it prevents, interrupts, removes, or only inconveniences.

Control	Targets	Residual risk if used alone	Verification evidence
FIDO2 MFA	MFA fatigue / phishing	Existing tokens and rogue methods may remain.	Registration and successful phishing-resistant challenge.
Risk-based access	Anomalous sign-in and unmanaged device	A previously issued session may remain valid.	Policy simulation and denied high-risk test sign-in.
Session revocation	Token replay	Password and factors may still be compromised.	Revocation event and failed token refresh/access.
Disable account	New authentication	Existing application sessions may require explicit revocation.	Account state and blocked authentication attempt.
Remove rogue MFA	Persistence	Active attacker session or known password may remain.	Factor inventory and audit event.
Password reset	Known password	Active sessions may survive; MFA fatigue remains possible.	Credential-change event plus independent session validation.
Block source IP	Observed network origin	Adversary can change infrastructure; token remains valid.	Network rule hit and monitoring for alternate sources.

Recommended operational sequence

There is no universal order for every incident, but this case supports a defensible sequence: preserve identifiers and current evidence; revoke sessions; temporarily disable the identity; remove unauthorized methods; reset the credential; require phishing-resistant recovery; enforce risk and device policy; validate that old tokens fail; review payroll access; and monitor for re-entry. Parallel work is appropriate when responders can preserve evidence while containment proceeds.

Success criteria

- Old sessions can no longer refresh or access the payroll vault.
- The rogue authenticator is absent and no other unapproved method exists.
- The recovered user authenticates with a phishing-resistant factor from a compliant device.
- High-risk or anomalous access is denied, challenged, or escalated according to approved policy.
- Evidence and decisions remain linked to Case PA-042 with stable timestamps and integrity information.

PORTFOLIO TALKING POINT The strongest explanation is capability-based: say exactly which attacker capability each control removes and what evidence proves the change. Avoid claiming that a high score automatically means the case is closed.

SECTION 20

Evidence Room: correlate and preserve

Use the evidence timeline to validate the attack narrative and separate observations from assumptions.

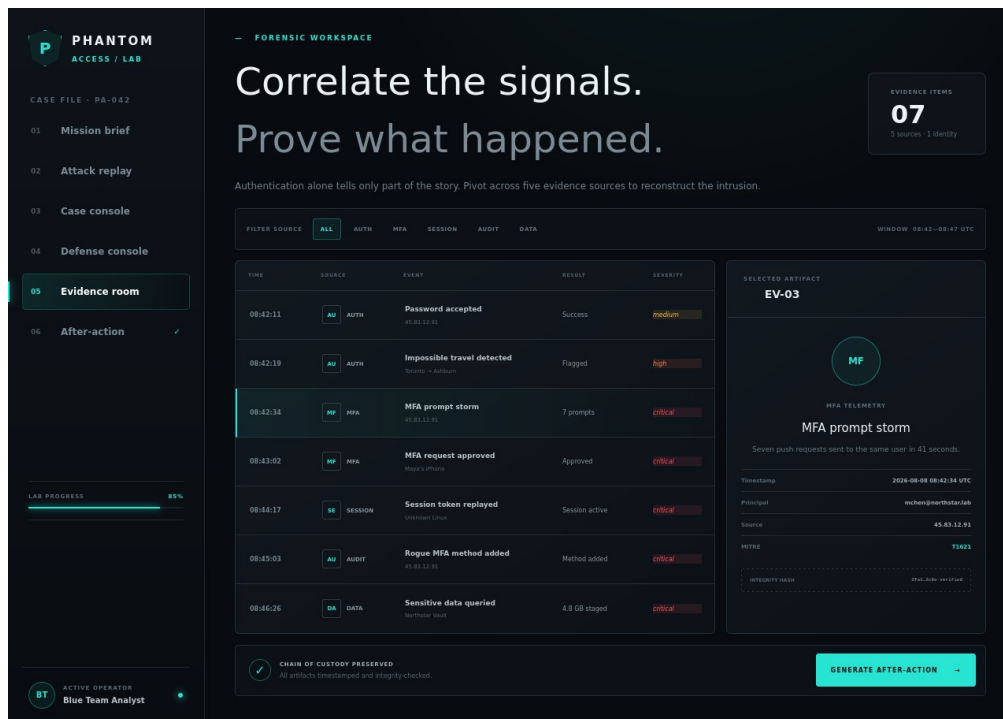


Figure 13. Evidence Room with seven events and the MFA prompt-storm artifact selected.

Evidence workflow

1. Review all seven events in chronological order before filtering.
2. Use category, severity, result, or search controls to test a specific hypothesis.
3. Select an artifact and compare its time, subject, source, result, description, and ATT&CK mapping with the replay and console outputs.
4. Record the evidence identifier, displayed integrity hash, and custody information in the case notes.
5. Identify any gap where the interface presents a conclusion without the underlying raw record; label it as simulated evidence in the report.

Selected artifact: EV-03

Figure 13 focuses on the MFA prompt storm. This artifact is pivotal because it connects valid credentials to the later approval and session. The analyst should correlate the seven requests within 41 seconds, the seventh approval, the source session sess-F09, and the user's expected activity. The prompt count alone does not prove malicious intent; the location, device, session, and subsequent persistence events make the pattern high confidence.

SECTION 21

Evidence handling and analysis questions

A strong report preserves provenance, records limits, and invites another analyst to reproduce the reasoning.

Evidence record template

Field	What to record
Evidence ID	Stable artifact identifier, such as EV-03.
Case / principal	PA-042 and mchen@northstar.lab.
Source	Authentication, MFA, session, audit, data access, or UI simulation.
Time basis	Displayed timestamp and time zone; note that the lab uses a fictional fixed sequence.
Observed fact	What the interface directly shows without interpretation.
Analyst inference	What the correlation suggests and the confidence level.
Integrity	Displayed hash or checksum, collection method, and any transformation.
Custody	Who collected, reviewed, exported, or transferred the artifact and when.
Limitation	Missing raw logs, simulated data, incomplete network context, or unconfirmed exfiltration.

Analysis questions

- Which event is the earliest high-confidence sign of compromise, and which event is the earliest opportunity for automated prevention?
- What proves that sess-F09 is not merely a second legitimate device used by Maya?
- Does AddAuthenticationMethod show the actor, target, and owning device clearly enough to conclude persistence? What additional audit fields would you seek?
- What evidence distinguishes data access, staging, download, and confirmed exfiltration?
- Which case statements are direct observations, which are tool-generated conclusions, and which are analyst inferences?

Chain-of-custody note

For this educational simulation, chain of custody demonstrates disciplined documentation rather than legal admissibility. In a real engagement, follow organizational evidence procedures, preserve originals, work from verified copies, record time zones, minimize transformations, and avoid actions that overwrite volatile logs before collection.

QUALITY CHECK Every conclusion in the after-action narrative should be traceable to at least one event, screen, or output. If a claim cannot be traced, qualify or remove it.

SECTION 22

After-Action dashboard

Use the final dashboard to summarize outcome, not to replace the underlying timeline and evidence.

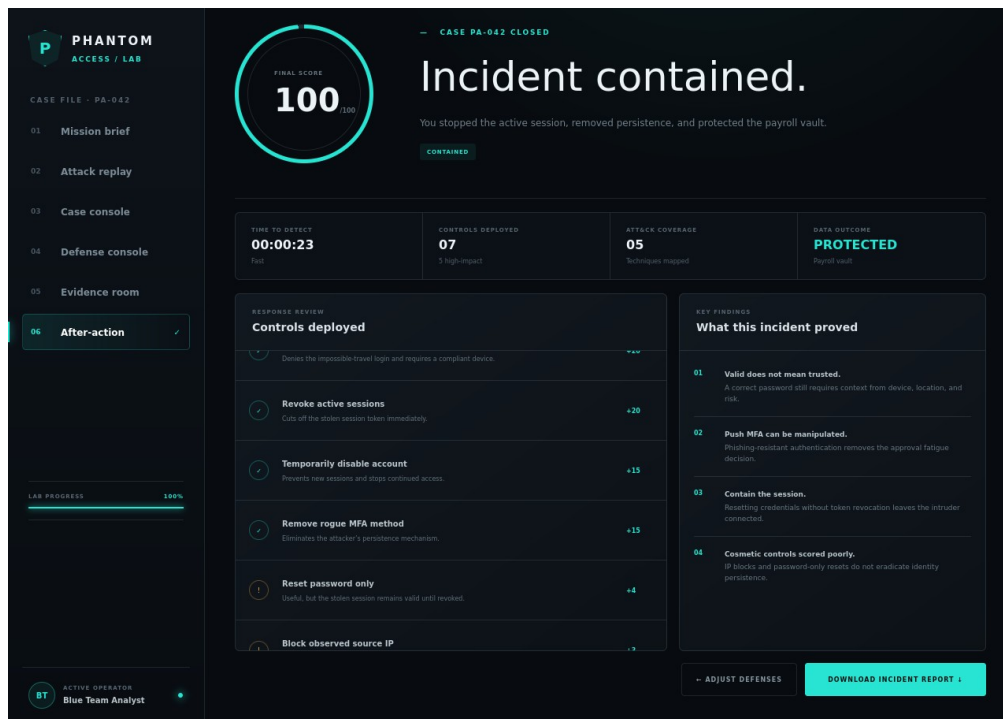


Figure 14. After-Action dashboard showing a 100 score, contained outcome, metrics, and findings.

Required final statements

- Outcome: incident contained in the simulation after the complete seven-control set was activated.
- Root control gap: the legacy finance access policy allowed a high-risk, unmanaged, anomalous session because risk signals were not enforced.
- Primary attack path: valid credential use, MFA request generation and approval, session replay, rogue factor registration, and sensitive repository access.
- Most important containment action: revoke active sessions; password reset alone does not invalidate every active token.
- Most important preventive improvements: phishing-resistant MFA plus risk- and device-aware access decisions.

Report structure

1. Executive summary: business impact, current state, and highest-priority action.
2. Scope and safety: fictional lab boundaries and environment.
3. Timeline: seven events with sources and identifiers.
4. Findings: identity, MFA, token, persistence, access-policy, and data-impact analysis.
5. Response: controls selected, order, verification, and residual risk.
6. Lessons and next steps: hardening, monitoring, and recovery requirements.

SECTION 23

Download and validate the text report

The exported file is a concise machine-readable handoff; compare it with the UI before treating it as complete evidence.

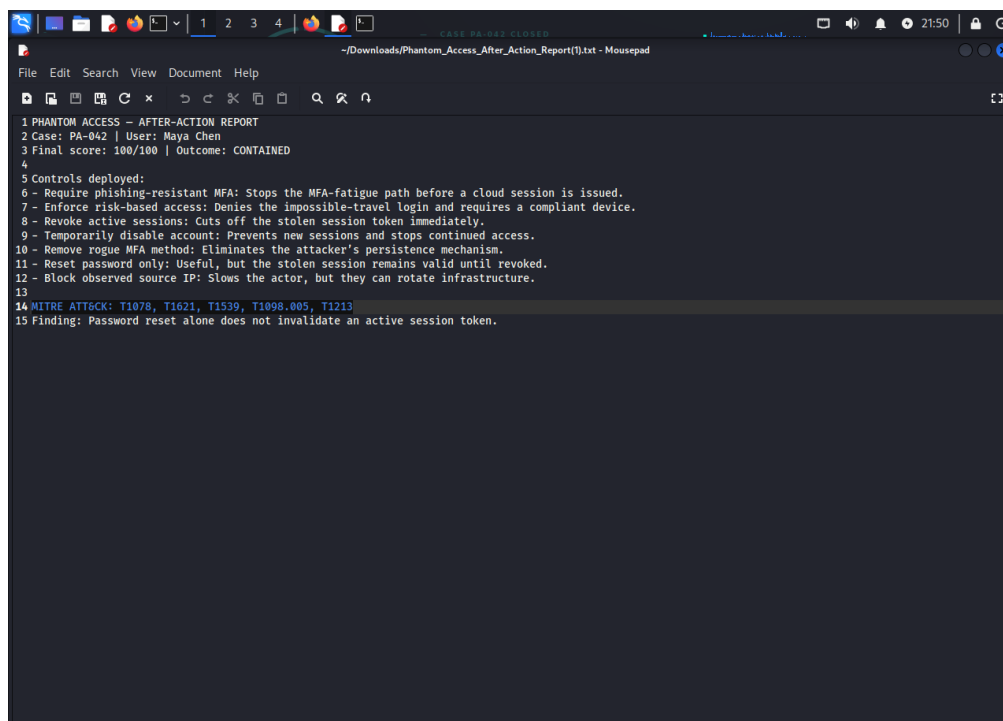


Figure 15. Downloaded Phantom Access after-action text report opened in Kali Mousepad.

Validate the export

1. Select Download report from the After-Action tab.
2. Open Phantom_Access_After_Action_Report.txt in a text editor.
3. Confirm Case PA-042, Maya Chen, score 100/100, and outcome CONTAINED.
4. Confirm all seven deployed controls appear and the ATT&CK line lists T1078, T1621, T1539, T1098.005, and T1213.
5. Confirm the finding that password reset alone does not invalidate an active session token.

Preserve the run

```
cd ~/Downloads  
sha256sum Phantom_Access_After_Action_Report.txt  
stat Phantom_Access_After_Action_Report.txt
```

Record the checksum and file metadata in the case notes. The checksum documents the exact exported version you reviewed; it does not validate the truth of the simulated contents. Keep the original text file unchanged and create a separate annotated copy if commentary is needed.

EVIDENCE LIMIT The text export is a summary generated from selected controls and fixed case data. It should be packaged with the screenshots and analyst notes rather than used as the only incident record.

SECTION 24

MITRE ATT&CK mapping

ATT&CK provides a common language for adversary behavior; it does not determine severity, intent, or containment on its own.

ID	Technique	Lab evidence	Defensive focus
T1078	Valid Accounts	Password accepted for Maya from an unrecognized browser.	MFA, conditional access, identity analytics, privileged account governance.
T1621	MFA Request Generation	Seven push requests in 41 seconds; the seventh is approved.	Phishing-resistant MFA, number matching, user reporting, rate limits, correlation.
T1539	Steal Web Session Cookie	Duplicated token fingerprint across trusted and unmanaged devices; 96% replay confidence.	Session binding, token protection, revocation, device posture, anomalous session detection.
T1098.005	Account Manipulation: Device Registration	Unknown device RAVEN-31 registers an authenticator after compromise.	Factor governance, audit alerts, approval, inventory review, rapid removal.
T1213	Data from Information Repositories	Payroll archive is opened and 4.8 GB staged.	Least privilege, repository auditing, DLP, sensitivity labels, egress validation.

Mapping notes

- The impossible-travel label DET0400 is a lab detection identifier. It should not be presented as an ATT&CK technique ID.
- One event can support more than one analytic hypothesis, but each mapping should be justified by the actual behavior shown.
- Technique coverage does not prove a control is effective. Verify prevention or containment through outcome evidence.

Primary official references

- [MITRE ATT&CK T1078 - Valid Accounts](#)
- [MITRE ATT&CK T1621 - MFA Request Generation](#)
- [MITRE ATT&CK T1539 - Steal Web Session Cookie](#)
- [MITRE ATT&CK T1098.005 - Device Registration](#)
- [MITRE ATT&CK T1213 - Data from Information Repositories](#)

SECTION 25

Zero Trust and incident-response analysis

The lab demonstrates why trust must be evaluated continuously and why response must act on identity, session, device, and resource together.

Zero Trust decision failure

The Case Console evaluates mchen@northstar.lab against the restricted payroll-vault resource. It observes high sign-in risk, an unmanaged device, and an anomalous location, yet the legacy-finance-access policy returns ALLOW because the signals are not enforced. The failure is therefore not a lack of telemetry; it is a failure to use that telemetry in the access decision.

Decision input	Observed	Desired enforcement
Identity	Valid credential but high-risk principal context	Require additional assurance or deny until investigated.
Device	Unmanaged Linux device	Require compliant or explicitly trusted device for restricted payroll access.
Location / behavior	Impossible travel and anomalous source	Block, step up, or route to risk review.
Session	Duplicated token fingerprint	Revoke and prevent reuse outside the expected context.
Resource	Restricted payroll vault	Apply stronger policy than ordinary low-sensitivity applications.

Incident-response lifecycle

Phase	Phantom Access activity
Preparation	Kali VM, safe simulation boundary, prerequisites, evidence plan, and expected outputs.
Detection and analysis	Attack Replay, six Case Console investigations, timeline, ATT&CK mapping, and hypothesis testing.
Containment	Session revocation, temporary disablement, rogue-factor removal, and tactical IP restriction.
Eradication and recovery	Credential reset, FIDO2 requirement, compliant-device and risk policy, controlled account restoration.
Post-incident	Evidence review, exported report, lessons, policy exception review, and monitoring improvements.

Reference: [NIST SP 800-207, Zero Trust Architecture](#)

CORE LESSON Zero Trust does not mean blocking every request. It means making an explicit, resource-aware decision from current signals and continuously reevaluating access rather than inheriting trust from one successful password or MFA event.

SECTION 26

Troubleshooting

Diagnose the layer that failed: archive layout, runtime, dependencies, process, VM networking, browser state, or export location.

Symptom	Likely cause	Safe corrective action
replace .npmrc? prompt	Extracting over an earlier copy.	Press N or Ctrl+C; extract into a clean directory. Use A only when intentional and local changes are preserved.
npm ERR! enoent package.json	Command issued outside the project root.	Run pwd and ls; change into the directory containing package.json.
Unsupported engine / Node version	Node is older than 22.13.0.	Install a supported release from a trusted source, reopen the terminal, and verify node --version.
npm install fails	Network, registry, disk, permissions, or corrupted cache problem.	Read the first fatal error, verify connectivity and disk, keep normal-user ownership, then retry.
Port 5173 already in use	Another Vite or development process is running.	Stop the known process with Ctrl+C or use the alternate port Vite prints. Do not kill unknown processes blindly.
localhost works only in Kali	localhost on the host refers to the host, not the VM.	Use the VM network URL or configure an explicit, local-only NAT port mapping.
VM IP does not open	Network mode, firewall, route, or wrong address.	Confirm Vite uses --host 0.0.0.0, recheck ip addr, and verify the host can reach that interface.
Blank or stale page	Cached client state or stopped server.	Check the Vite terminal, refresh the page, and restart the local server if required.
Console controls do not advance	A previous run or browser state is inconsistent.	Use the app's reset/restart path or reload, then rerun in order.

Symptom	Likely cause	Safe corrective action
Report not found	Browser download location differs.	Check the browser downloads list and ~/Downloads; search by the exact Phantom_Access_After_Action_Report.txt name.

Diagnostic commands

```
pwd && ls -la
node --version && npm --version
ss -ltnp | grep 5173
ip addr show
curl -I http://localhost:5173/
```

TROUBLESHOOTING DISCIPLINE Change one condition at a time and record the result. Preserve the first fatal error and the command that produced it; later errors are often downstream symptoms.

SECTION 27

Validation checklist and assessment

Use this page as the final run sheet for a reproducible lab submission.

Environment and launch

- ☐ Kali VM resources and network mode recorded.
- ☐ Node.js version is 22.13.0 or newer; npm version recorded.
- ☐ Archive extracted without accidental overwrite; package.json located.
- ☐ npm install completed without a fatal error.
- ☐ Vite displayed local and/or network URL; GET / returned 200.

Case execution

- ☐ Mission Brief identity, role, organization, and objectives recorded.
- ☐ All seven attack events replayed and narrated in order.
- ☐ All six Case Console investigations completed and key outputs recorded.
- ☐ Baseline, exposed 43, partial 54, and contained 100 states compared.
- ☐ All seven evidence artifacts reviewed; EV-03 integrity and custody fields noted.
- ☐ Text report downloaded, validated, and hashed.

Assessment prompts

1. Explain why successful password and MFA checks can still produce an untrustworthy access decision.
2. Explain why session revocation receives more scenario credit than password reset alone.
3. Identify the event that creates persistence and the evidence needed to remove it safely.
4. Distinguish data staging from confirmed exfiltration.
5. Propose one detection improvement, one preventive control, and one recovery validation.

Suggested rubric

Area	Weight	Full-credit evidence
Installation	20%	Correct project root, supported runtime, successful host, reproducible notes.
Attack analysis	25%	Accurate seven-event chain with facts separated from inference.
Investigation	20%	Six console outputs interpreted as decisions, not copied without explanation.
Defense	20%	Control capabilities, residual risks, and verification explained.
Evidence/reporting	15%	Custody, integrity, limits, exported report, and clear narrative.

SECTION 28

Conclusion, portfolio narrative, and references

The completed lab demonstrates identity-centered incident analysis from first signal to verified recovery plan.

Conclusion

Phantom Access shows how a cloud incident can unfold without malware: a valid credential, an approved push, and a portable session can be enough. The decisive analytical move is to stop treating authentication success as trust and instead correlate identity risk, device posture, session behavior, administrative changes, and resource sensitivity. The decisive response move is to act on the active session and persistence path, then recover the user under stronger policy.

Portfolio-ready description

PROJECT SUMMARY Built and documented Phantom Access, a safe browser-based cloud identity incident lab hosted in a Kali Linux VM. The lab visualizes a seven-event attack chain involving valid-account abuse, MFA fatigue, session replay, rogue-factor persistence, and sensitive-data access. I designed a command-driven investigation workflow, evaluated weighted Zero Trust controls, preserved evidence, and produced a scored after-action report without connecting to a live tenant or using real credentials.

What to demonstrate live

- Start at the mission brief and state the identity and business risk in under 30 seconds.
- Replay the chain while naming the control opportunity at each transition.
- Run the Case Console one command at a time and explain the decision enabled by each result.
- Compare the 43-, 54-, and 100-point defense states to show capability-based reasoning.
- Finish in the Evidence Room and after-action report, emphasizing verification and limits.

References and source notes

- Phantom Access source package and README, version 0.1.0 (project-local source).
- [MITRE ATT&CK Enterprise technique pages for T1078, T1621, T1539, T1098.005, and T1213.](#)
- [NIST Special Publication 800-207, Zero Trust Architecture.](#)
- Node.js runtime requirement from the project package manifest: version 22.13.0 or newer.
- Figures 1-15: screenshots supplied by the lab author, captured 07 Aug 2026.

Final statement

This guide documents an educational simulation. It does not authorize testing against real identities, tenants, users, networks, or services. Apply the analytical concepts only within approved scope and follow the evidence, privacy, and change-control procedures of the environment you are responsible for.

END OF LAB GUIDE / CASE PA-042